

PROJET DE VALIDATION - BLOC 1 (RNCP 38777)

Stratégie et implémentation de la gouvernance des données

Blueprint opérationnel vers le niveau "Managed" chez Spotify S.A.

Auteur : Candidat au titre d'architecte en IA

Date de présentation : Juin 2026

Plan

1. Diagnostic de maturité
2. Modèle opératoire cible & organisation
3. Architecture de données & conformité
4. POC et protocoles d'urgence
5. Roadmap & Valorisation

Diagnostic de maturité des données de Spotify

État des lieux initial chez Spotify (Transition 2020) :

L'hyper-croissance et la migration intégrale vers le cloud ont généré une fragmentation de l'architecture technique, menaçant la traçabilité et la qualité globale.

Maturité initiale

Niveau 2 : Reactive (Gartner)

Une gestion locale, fragmentée et réactive face aux pannes ou requêtes légales.

Cible à 18 mois

Niveau 4 : Managed (Gartner)

Gouvernance invisible, automatisée et intégrée nativement dans le flux de dev

1. Fragmentation sémantique

Incohérences de définitions : Rupture de langage entre les équipes agiles.

Silos d'information : Duplications inutiles d'ingestions de données.

2. Pipelines & actifs orphelins

Zéro traçabilité : Des milliers de tables sans propriétaire identifié.

Explosion cloud : Risques financiers majeurs et pannes non résolues.

3. Rupture de traçabilité IA

Origine floue : Difficulté d'auditer l'origine des données d'entraînement.

Reproductibilité : Risque de biais et d'obsolescence sémantique.

4. Risques réglementaires

Conformité de masse : Complexité du RGPD (CNIL/EDPB) et CCPA en production.

Sanctions : Exposition cyber aux fuites de données d'écoute sensibles.

4 objectifs stratégiques de la gouvernance

La notion de Source Unique de Vérité (SSOT) :

Au cœur de notre feuille de route se trouve la création d'un référentiel de données unifié pour éradiquer les silos.

Toutes les équipes de Spotify s'alignent sur une sémantique commune de métadonnées partagées pour l'analyse et la recommandation d'IA.

1. Briser les silos métiers

Décloisonnement : Connecter de manière sécurisée les bases marketing, financières et comportementales.

Coopération : Harmoniser les pipelines pour éliminer les doublons techniques.

2. Conformité stricte & globale

Multi-régulations : Assurer la conformité automatisée RGPD (Europe), CCPA (Californie) et PCI-DSS.

Confiance : Garantir la souveraineté et le respect des droits des abonnés.

3. Qualité de donnée accrue

Exactitude accrue : Améliorer les indicateurs de qualité de 20 % à l'ingestion.

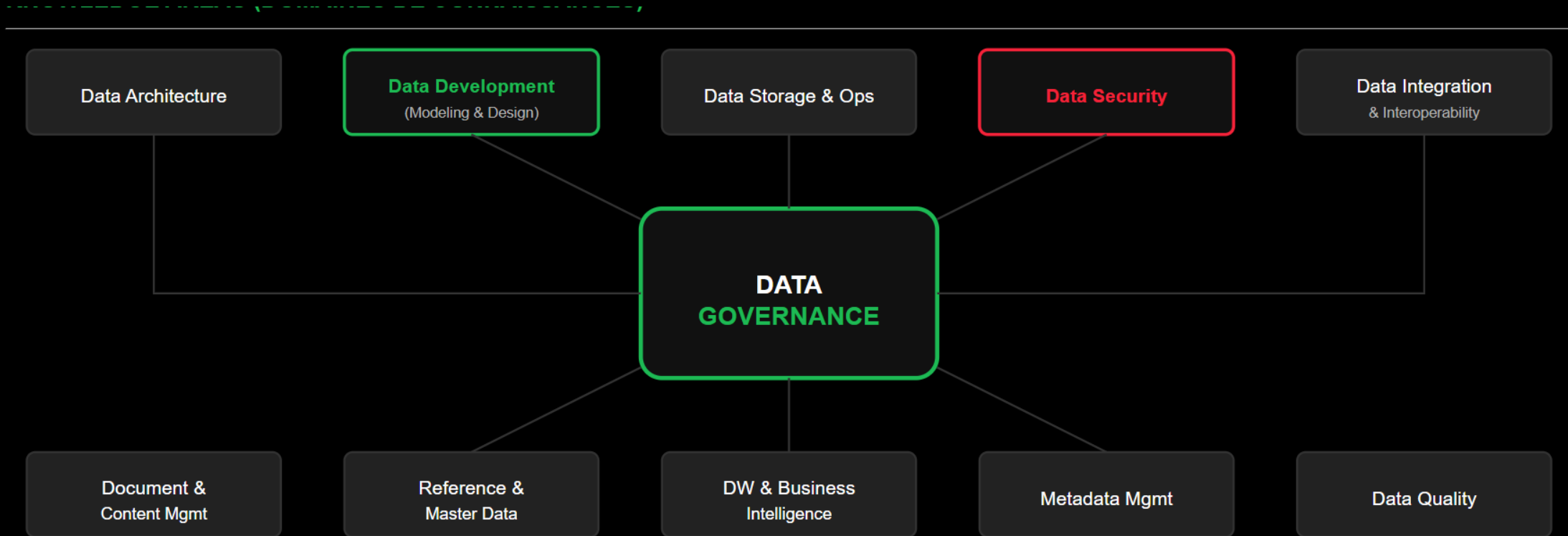
Algorithmes fiables : Fournir des données propres pour éliminer les biais des modèles d'IA.

4. Source unique de vérité

Master Data unifié : Standardiser les modèles conceptuels de référence.

Catalogue central : Backstage comme registre universel, traçable et auditable.

Cadre d'analyse DMBOK



Note : Le domaine 'Data Development' inclut la modélisation et le cycle de vie applicatif.

Principes fondamentaux vs axes DMBOK

1. RESPONSABILITÉ

Accountability : rôles,
DPO & Data Stewards.

Axe: Data Governance

2. TRANSPARENCE

Information claire sur
l'usage (streaming).

Axe: Metadata mgt

3. SÉCURITÉ

Chiffrement fort (KMS)
& cloisonnement bancaire.

Axe: Data Security mgt

4. QUALITÉ CONTINUE

Audits auto & nettoyage
lors de l'ingestion.

Axe: Data Quality mgt

5. MINIMISATION

Modeling & design:
minimisation collecte / besoins pub.

Axes: Data Arch & Ops; data devpt

6. DROITS USERS

Accès facilité et
effacement automatisé.

Axe: Document & Content

7. AMÉLIORATION

Agilité face aux régul.
(ex: EU AI Act).

Axe: Data Warehouse & BI

8. ÉTHIQUE ALGO

Modèles IA sans biais
de genre ou d'artiste.

Axe: Reference & Master

Adoption du modèle "center of excellence" (CoE)

Pourquoi un Center of Excellence (CoE) ?

Ce modèle garantit l'alignement global pour plus de 7 000 collaborateurs répartis mondialement.

Il assure une coordination centrale tout en embarquant l'expertise directement dans les divisions métiers.

Division marketing

Périmètre : Données de prospects, comportement de streaming.

Steward embarqué : Alignement OneTrust, élimination des doublons de prospects.

Sémantique : Tracking du parcours utilisateur d'acquisition.

Division finance

Périmètre : Facturation, transactions, flux d'abonnement.

Steward embarqué : Conformité stricte aux exigences PCI-DSS.

Sémantique : Données de paiement isolées (CDE).

Division tech & R&D IA

Périmètre : Algorithmes de recommandation, modèles prédictifs.

Steward embarqué : Traçabilité des données d'entraînement d'IA.

Sémantique : Élimination des biais, explicabilité des modèles.

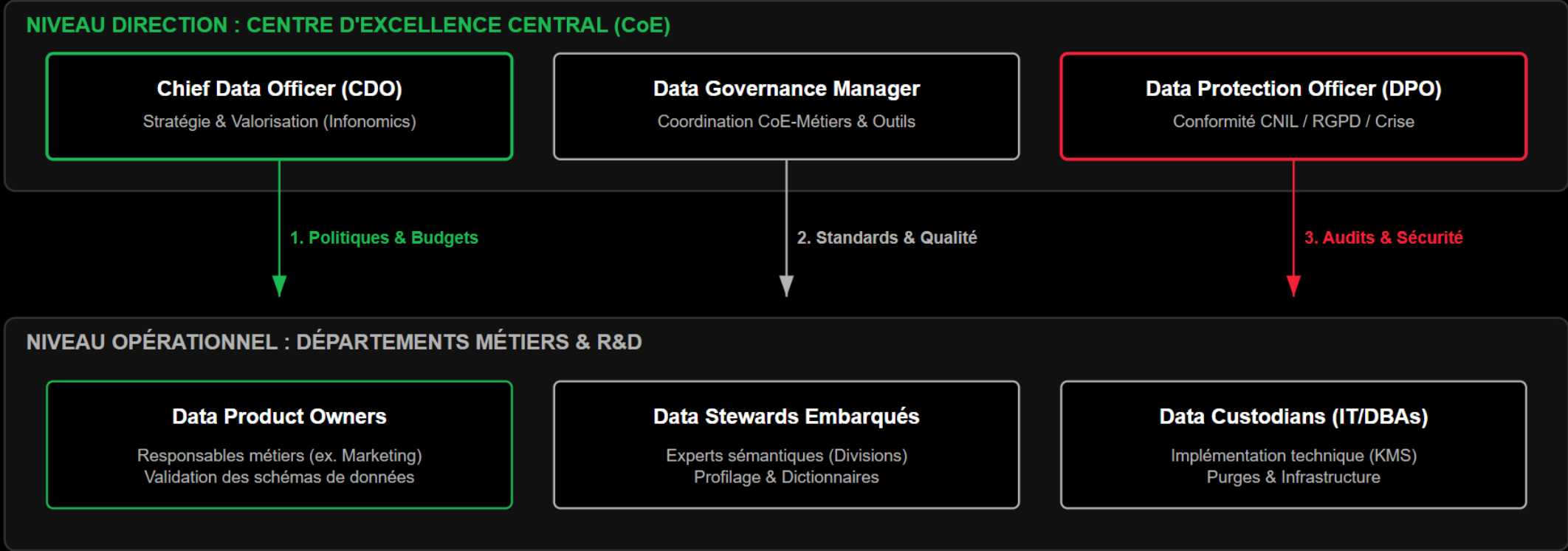
Division RH

Périmètre : Données des collaborateurs, dossiers personnels.

Steward embarqué : Contrôle strict des données confidentielles.

Sémantique : Habilitations IAM d'accès selon le profil.

Organigramme des rôles et responsabilités



Modèle hybride : Pilotage centralisé par le CoE / Exécution décentralisée dans les Squads métiers.

La matrice RACI (responsabilités clés du programme)

1. CADRAGE & STRATÉGIE

Politiques de la charte

CDO (A) | Comité (R) | DPO/Stewards (C)

Modèle de maturité

CDO (A) | Comité (R) | Stewards (R)

Veille IA Act / réglementaire

DPO (A) | CDO (R) | Comité (R)

2. OPÉRATIONS & QUALITÉ

Catalogage & backstage

Owner (A) | Steward (R) | Engineer (R)

Contrôle qualité continue

Owner (A) | Steward (R) | Custodian (C)

Habilitations & IAM

Owner (A) | Steward (R) | Custodian (R)

Accessibilité (RGAA)

Owner (A) | Steward (C) | Engineer (R)

3. CONFORMITÉ & URGENCES

Analyses d'impact (AIPD)

DPO (A) | Owner (R) | Steward (R)

Purges & anonymisation

DPO (A) | Custodian (R) | Engineer (R)

Protocoles d'urgence (crises)

DPO (A) | CDO (R) | Comité (R)

R Responsable (Réalise)

A Accountable (Approuve)

C Consulted (Consulté)

I Informed (Informé)

Gouvernance fédérée & automatisation technique

Gouvernance invisible intégrée :
L'autonomie des Squads de développement est préservée. Zéro contrôle bureaucratique manuel.

La propriété des données est codifiée et gérée comme du code logiciel versionné.

Responsabilisation Git

Fichier owner.yaml : Fichier standardisé obligatoire à la racine de chaque dépôt.

Métadonnées clés : Identité du Data Owner, canal Slack d'équipe, et périmètre sémantique.

Zéro Orphelin : Aucun pipeline ne peut être déployé en production sans propriétaire déclaré.

Le portail Backstage

Registre Automatique : Extraction asynchrone des owner.yaml pour cartographier le catalogue.

Visualisation : Cartographie dynamique du lignage technique (lineage) de bout en bout.

Découverte intelligente : Moteur sémantique de recommandation de jeux de données valides.

Gouvernance invisible

Conformité fluide : Intégration dans les outils quotidiens des développeurs.

Modèles prêts à l'usage : Templates (Golden Paths) de code pré-approuvés.

Zéro ralentissement : Accélère la vitesse tout en garantissant l'alignement.

Écosystème technologique de gouvernance recommandé

L'infrastructure technique de confiance :

Pour piloter notre flotte à l'échelle de 500 milliards d'événements par jour, nous unifions les pratiques sur un ensemble d'outils cloud certifiés et intégrés.

1. Catalogage & métadonnées

Outils : Backstage (interne) & DataHub.

Usages : découverte sémantique intelligente, recherche par intention, cartographie et lignage des flux.

2. Qualité des données

Outils : Talend (ingestion), Apache Beam / Scio & Monte Carlo.

Usages : profilage, nettoyage automatique lors de l'ingestion, et monitoring d'intégrité en temps réel.

3. Conformité & confidentialité

Outils : OneTrust & GCP Sensitive Data Protection (SDP).

Usages : registre des traitements, gestion des consentements (CMP), et routage d'exercice des droits (DSR).

4. Sécurité & chiffrement

Outils : GCP Cloud KMS, CMEK (BigQuery) & Splunk SIEM.

Usages : chiffrement par colonne, rotation automatique des clés, VPC Service Controls, et monitoring des menaces.

Socle éthique, veille et accessibilité numérique

Inclusion & accessibilité

- **Normes de Conception** : alignement complet sur les exigences d'accessibilité RGAA 4.1.2 et WCAG 2.2.
- **Outils BI Internes** : conception de dashboards (Looker, Tableau) compatibles avec les lecteurs d'écran professionnels (balises ARIA).
- **Navigation au Clavier** : accès intégral aux fonctionnalités et contrastes de couleurs adaptés aux collaborateurs daltoniens.
- **Services clients inclusifs** : intégration de commandes vocales avancées et sous-titrages automatiques en temps réel pour l'audio.

Veille réglementaire continue

- **Processus Structuré** : processus d'évaluation bimensuelle associant le DPO, le service juridique et les architectes de données.
- **Suivi RGPD/ AI Act** : cartographie des systèmes de recommandation de Spotify selon les niveaux de risque de la réglementation européenne. Suivi des décisions/jurisprudence EDPB
- **Procédure d'impact technique** : évaluation de l'impact technique de toute nouvelle loi sous 15 jours par le Centre d'Excellence.
- **Pratiques éthiques** : suivi permanent des biais de recommandation pour éviter l'exclusion d'artistes ou stéréotypes de genres.

Confidentialité, chiffrement KMS et cycle de vie

Chiffrement KMS sélectif (ISO 27001)

- **Chiffrement par colonne** : Les informations personnellement identifiables (PII) subissent un chiffrement de colonne sélectif au repos.
- **Technologie GCP** : Intégration transparente dans Cloud BigQuery avec clés cryptographiques AES-256.
- **Rotation Automatique** : Renouvellement mensuel des clés via Cloud KMS sans interruption des pipelines d'entraînement IA.
- **Contrôle d'accès IAM** : Isolation stricte selon le principe du moindre privilège, barrant l'accès aux bases brutes aux administrateurs.

Cycle de vie automatisé & purges (RGPD / CCPA)

- **Destruction par le code** : les règles de rétention sont codées en dur sous forme de scripts automatisés liés à l'infrastructure.
- **Règle des 24 mois** : purge définitive ou anonymisation irréversible (hachage SHA-256) des logs d'écoute inactifs après 24 mois.
- **Orchestration des droits** : Traitement automatisé des requêtes utilisateurs (droit d'accès et d'effacement) via OneTrust.
- **Ressources orphelines** : automatisation de la purge des tables de staging inutilisées, participant à une démarche d'éco-conception.

Projet pilote : périmètre de la division marketing

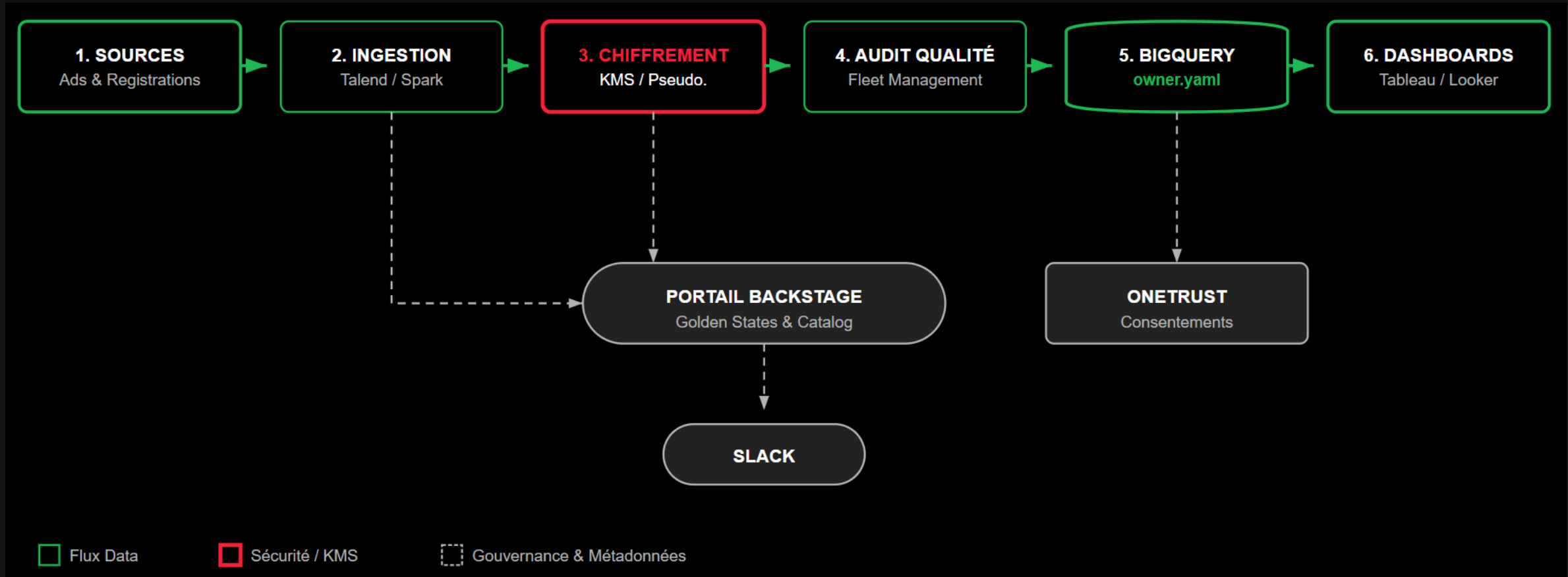
Périmètre & équipe du projet pilote

- **Le Périmètre Pilote** : Application des règles sur les flux de prospects et d'acquisition d'abonnés.
- **Le Volume** : Traitement de 15 à 20 TB de données d'activité d'écoute et de profils.
- **La Durée** : Déploiement rigoureux sur un cycle de 12 semaines.
- **L'Équipe Dédiée** :
 - 1 Data Steward (Marketing) pour superviser l'alignement sémantique,
 - 2 IT Engineers (Data Custodians) pour configurer les flux,
 - 1 Marketing Lead pour valider la qualité opérationnelle métier.

Critères de succès & KPIs d'évaluation

- ✓ **100 % des actifs catalogués** : tous les jeux de données marketing enregistrés dans Backstage avec un owner valide en 12 semaines (Cible : >98 %).
- ✓ **+15 % de qualité des données** : amélioration du score de qualité de 3.5 à 4.0/5 via des routines automatisées de nettoyage.
- ✓ **100 % de conformité RGPD** : ingestion conforme via OneTrust CMP (Zéro anomalie de consentement en production).
- ✓ **Équipe acculturée** : formation et certification interne de 20 utilisateurs clés de la division marketing à l'usage de Backstage.

Architecture technique du pipeline pilote sécurisé



Projet pilote : intégration et sémantique sociale

Flux technique d'ingestion sécurisé

- **Pipeline d'Ingestion** : Talend automatise l'import des prospects depuis les régies publicitaires.
- **Anonymisation** : Pseudonymisation automatique des adresses e-mail par hachage SHA-256 dès l'ingestion.
- **Synchronisation du Consentement** : OneTrust collecte le consentement. En cas d'opt-out, un webhook désactive en temps réel le pipeline d'analyse BigQuery correspondant.
- **Surveillance Qualité** : Monte Carlo surveille en continu la dérive de schéma de données et l'intégrité des tables de prospects.

La sémantique sociale & recherche d'intention

- **Dictionnaire Social** : Chaque fiche de table de données dans Backstage est liée dynamiquement au canal de discussion Slack de l'équipe de dev responsable.
- **Mise en relation** : Les analystes identifient instantanément l'expert humain sémantique, éliminant les lenteurs d'e-mails.
- **Recherche Intelligente** : Le moteur Backstage recherche par intention d'usage (ex. 'campagne été') plutôt que par requêtes de mots-clés techniques.
- **Gains mesurés** : Baisse de **40 %** du temps passé par les analystes à chercher et à explorer la sémantique de la donnée.

Gouvernance de flotte & plans de secours d'urgence

GOUVERNANCE DE FLOTTE

Fleet Management

Surveillance continue de l'intégrité vs audits.

The Golden States

Configurations de référence & schémas de val.

Alerte Automatique

Détection des dérives dès le 'commit' Git.

Éco-conception

Élimination des pipelines dormants / inutilisés.

Objectif : Zéro dérive technique

PROTOCOLE ALPHA : FUITE PII

Fenêtre critique : 72 Heures

Détection via SIEM Splunk.

T0 + 2h : Isolation

Révocation immédiate des clés API.

T0 + 24h : Notification CNIL

Dépôt légal (Art. 33 du RGPD).

T0 + 48h : Information Individuelle

Renouvellement forcé des credentials.

PROTOCOLE BETA : KMS DRP

Plan de Reprise (DRP)

Recouvrement de la clé maîtresse Cloud.

Secret Partagé (Shamir)

Quorum : 3/5 administrateurs certifiés.

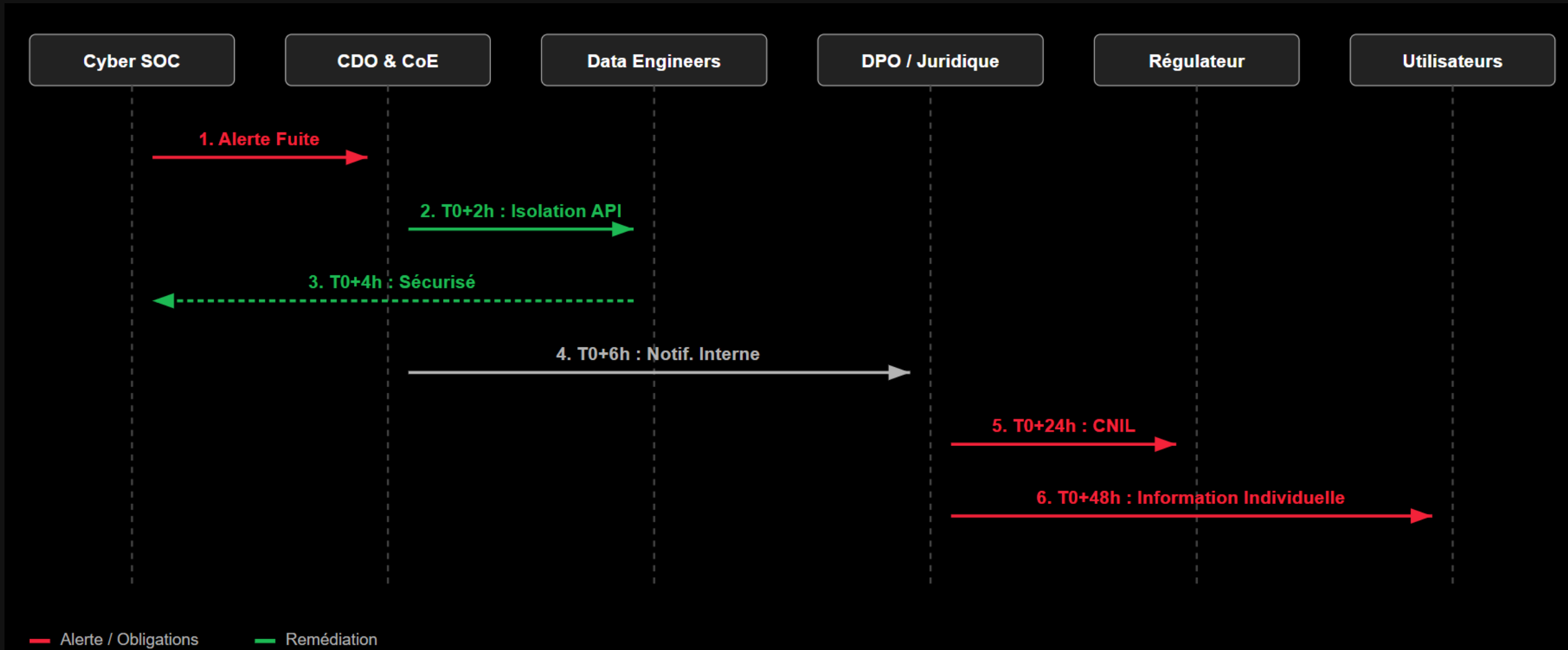
OBJECTIFS TECHNIQUES

RPO < 2 Heures

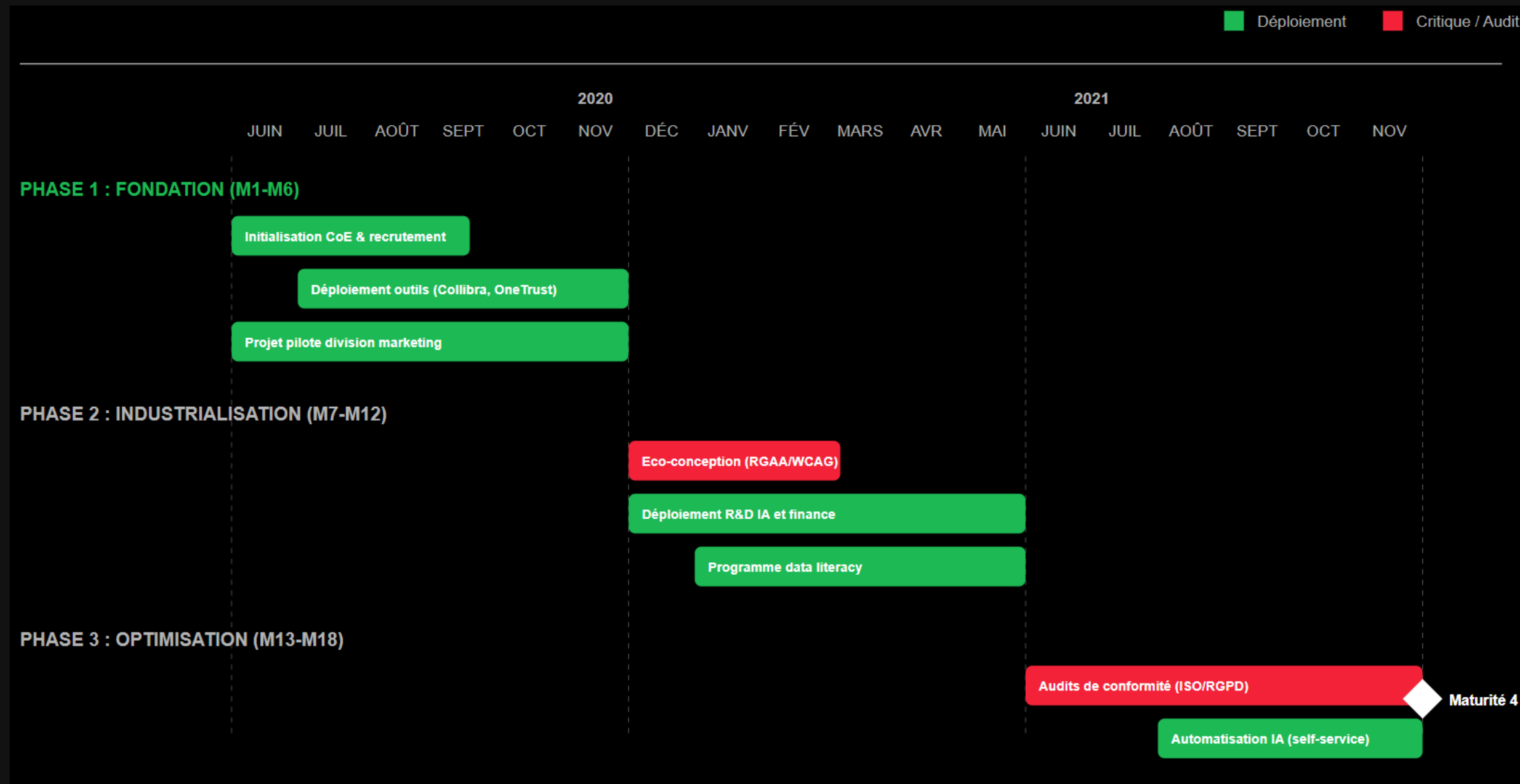
RTO < 8 Heures

Cible : Restauration profils utilisateurs.

Chronologie d'urgence : protocole Alpha



Roadmap implémentation de la gouvernance



Évaluation & mitigation des risques majeurs

1. Résistance culturelle (adoption)

- **Description** : Les Squads agiles perçoivent la gouvernance comme une lenteur bureaucratique.
- **Probabilité** : Élevée | Impact : Moyen | Criticité : Élevée (12/25)
- **Mitigation** : Change Management, formation, mise en place de 'Quick Wins', promotion de la gouvernance invisible comme accélérateur de dev (Golden Paths).

2. Complexité d'intégration (technique)

- **Description** : Difficultés de connecter les outils (Backstage, OneTrust, Cloud KMS) à l'existant.
- **Probabilité** : Moyenne | Impact : Moyen | Criticité : Moyenne (9/25)
- **Mitigation** : Réalisation de POC (Proof of Concept) techniques préalables, support dédié des éditeurs et équipe IT dédiée au CoE.

3. Manque de ressources (humain)

- **Description** : Pénurie d'ingénieurs qualifiés en gestion et sécurité des données.
- **Probabilité** : Moyenne | Impact : Moyen | Criticité : Moyenne (9/25)
- **Mitigation** : Lancement d'un programme de formation certifiante interne et appui temporaire de consultants externes pour la structuration initiale.

4. Évolutions réglementaires (légal)

- **Description** : Nouvelles lois de protection des données nécessitant de réécrire les processus.
- **Probabilité** : Faible | Impact : Élevé | Criticité : Moyenne (10/25)
- **Mitigation** : Veille continue assurée bimensuellement par le DPO, et utilisation d'une architecture Cloud (GCP) flexible et modulaire.

Valorisation économique et facteurs clés de succès

VALORISATION ÉCONOMIQUE (INFONOMICS)

-15%

Budget média d'acquisition

Élimination des pipelines doublonnés & données erronées

+25%

Rapidité de déploiement IA

Grâce à la qualification des données via Backstage

4%

Risque CA (Amendes RGPD)

Couverture proactive et automatisation de la conformité



Réduction Empreinte Carbone

Nettoyage automatique des tables orphelines (Cloud)

FACTEURS CLÉS DE SUCCÈS

- **Agilité des Squads**

Unifier les données sans ralentir les déploiements.

- **Governance-as-Code**

Automatisation via owner.yaml et Backstage.

- **Résilience & Normes**

Inclusion (RGAA) et plans de crise (Alpha/Beta).

Annexes

Organigramme des rôles et responsabilités

Niveau direction (comité de gouvernance)

- **Chief Data Officer (CDO) :**
 - Pilote stratégique globale, valorisation économique des actifs (Infonomics), arbitrage.
- **Data Protection Officer (DPO) :**
 - Indépendant, garant de la conformité CNIL/RGPD, AIPD, gestion du protocole de crise Alpha.

Niveau management (bureau de coordination)

- **Data Governance Manager :**
 - Chef d'orchestre opérationnel du Center of Excellence (CoE).
- **Responsabilités :**
 - Définition des standards,
 - Mise à disposition des outils,
 - Consolidation des indicateurs,
 - Lien CoE-métiers.

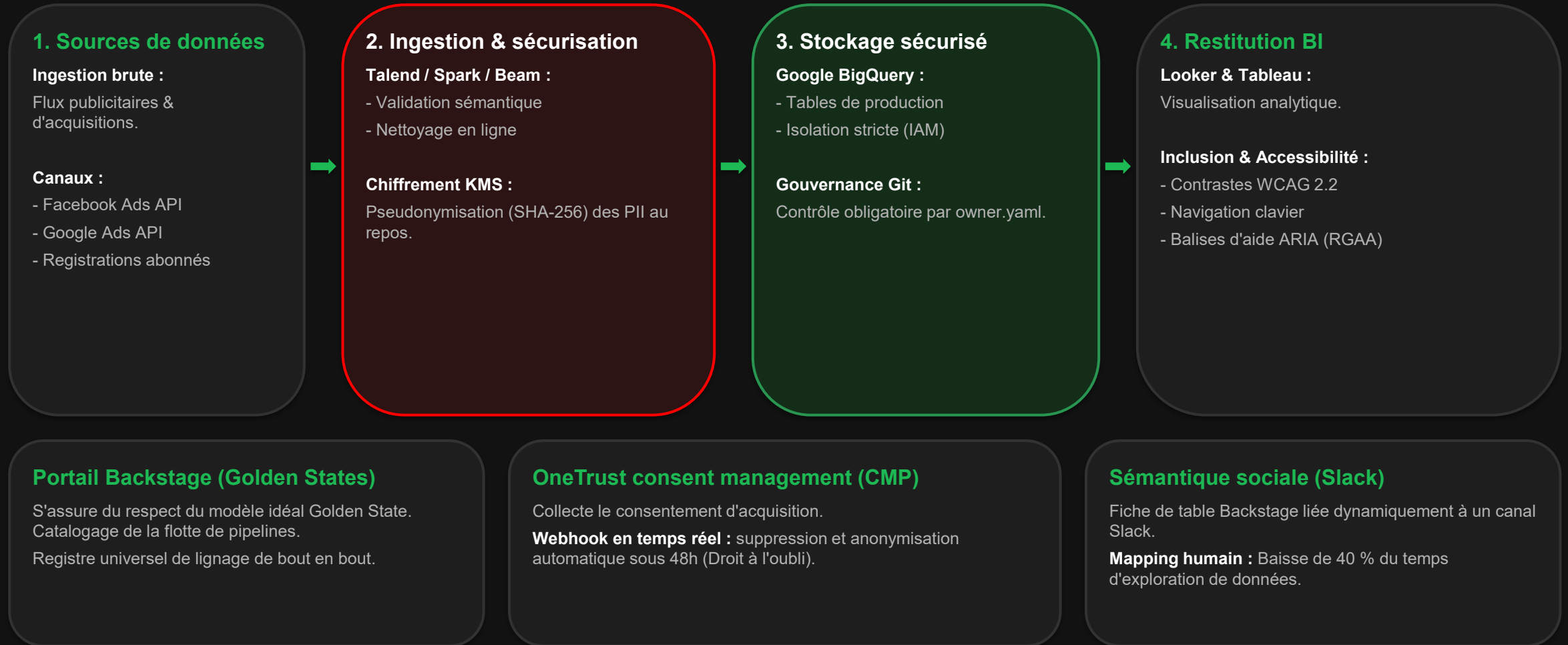
Niveau data stewards (experts métiers)

- **Data Stewards Embarqués :**
 - Un steward par division (Marketing, Finance, R&D IA, RH).
- **Responsabilités :**
 - Garantir la définition sémantique des dictionnaires,
 - Valider les contrôles de qualité,
 - Former les Squads agiles.

Niveau opérationnel (exécution technique)

- **Data Custodians (DBAs / Engineers) :**
 - Implémentation technique de l'infrastructure (chiffrement KMS, purges automatisées).
- **Department Heads / Data Product Owners :**
 - Alignement métier,
 - Validation de l'exactitude des schémas de données.

Architecture technique du pipeline pilote sécurisé



Feuille de route d'implémentation sur 18 mois

Phases d'implémentation

- **Phase 1** : Fondation (Mois 1 à 6) :
 - Nomination du Comité de Gouvernance et structuration du CoE.
 - Déploiement des solutions outillées (Collibra, OneTrust, Talend).
 - Réalisation du projet pilote Division Marketing.
- **Phase 2** : Passage à l'Échelle (Mois 7 à 12) :
 - Extension de la gouvernance à la R&D IA et à la direction Finance.
 - Mise en conformité d'accessibilité RGAA/WCAG de tous les dashboards BI
- **Phase 3** : Optimisation (Mois 13 à 18) :
 - Automatisation du lignage et audits de sécurité ISO 27001.
 - Atteinte visée du niveau 4 de maturité de Gartner.

Détail opérationnel par jalon

Mois 1-2 : Setup infrastructure (GCP/OneTrust) & formation du CoE.

Mois 3-4 : Inventaire Marketing, profiling initial & mapping des données sensibles (PII).

Mois 5-6 : Implémentation règles qualité, workflows conformité et publication des dashboards marketing.

Mois 7-9 : Extension Finance (PCI-DSS) et Tech (Traçabilité IA).

Mois 10-12 : Extension RH et optimisation globale avant rollout.

Mois 13-18 : Déploiement global, audit de sécurité ISO 27001, et passage de certification au niveau 'Managed'.

Les 8 principes fondamentaux & axes DMBOK

1. Responsabilité (accountability)

Définition claire des rôles, encadrée par le DPO et les Data Stewards.

****Axe DMBOK correspondant :**** Data Governance

2. Transparence

Notice d'information claire sur l'usage des données de streaming.

****Axe DMBOK correspondant :**** Metadata Management

3. Sécurité des données

Chiffrement fort (KMS) et cloisonnement des données bancaires.

****Axe DMBOK correspondant :**** Data Security Management

4. Qualité continue

Audits automatiques et nettoyage des métadonnées lors de l'ingestion.

****Axe DMBOK correspondant :**** Data Quality Management

5. Minimisation de la donnée

Collecte strictement limitée aux besoins du service d'écoute et pub.

****Axe DMBOK correspondant :**** Data Architecture & Operations

6. Droits des utilisateurs

Systèmes automatisés de téléchargement (accès) et effacement.

****Axe DMBOK correspondant :**** Document & Content Management

7. Amélioration continue

Évolution agile face aux nouvelles régulations (ex. EU AI Act).

****Axe DMBOK correspondant :**** Data Warehouse & BI Management

8. Éthique algorithmique

Modèles d'IA transparents, exempts de biais de genre ou d'artiste.

****Axe DMBOK correspondant :**** Reference & Master Data

Gouvernance de flotte & plans de secours d'urgence

Gouvernance de flotte

- **Concept de Fleet Management** : Surveillance continue de l'intégrité de la flotte de pipelines plutôt que des audits manuels.
- **Les Golden States** : Définition de configurations types de référence (versions logicielles, schémas de validation).
- **Alerte Automatique** : Détection immédiate des dérives techniques dès la phase de commit sous Git.
- **Eco-conception** : Élimination des pipelines dormants ou non-utilisés.

Protocole Alpha : fuite de PII

- **Gestion d'Incident (72 heures)** : S'active dès la détection d'une fuite de données personnelles par le SIEM Splunk.
- **T0 + 2 heures** : Isolation réseau stricte des instances, désactivation immédiate des clés d'accès compromises.
- **T0 + 24 heures** : Notification légale détaillée rédigée par le DPO pour la CNIL (Art. 33 du RGPD).
- **T0 + 48 heures** : Notification individuelle des abonnés concernés et renouvellement obligatoire de leurs mots de passe.

Protocole Beta : KMS DRP

- **Plan de Reprise après Sinistre** : Procédure de recouvrement de la clé maîtresse Cloud KMS détruite ou corrompue.
- **Secret Partagé** : Recomposition de la clé d'administration via la clé de Shamir (requiert 3 des 5 administrateurs certifiés).
- **Objectifs Techniques de DRP** : Restauration des services et bases de données profils utilisateurs avec un RPO < 2 heures et un RTO < 8 heures.

Chronologie d'urgence pas-à-pas : protocole Alpha



Valorisation économique et facteurs clés de succès

Valorisation économique (infonomics)

Optimisation Directe : Élimination des pipelines doublonnés et données marketing erronées permettant une économie de ****15 %**** du budget média d'acquisition.

Productivité R&D IA : Hausse de ****25 %**** de la rapidité de déploiement des modèles d'IA prédictifs en fournissant des données documentées et qualifiées par Backstage.

Réduction des Risques Cyber : Couverture proactive contre les amendes financières du RGPD (pouvant atteindre 4 % du chiffre d'affaires mondial).

Green IT & Éco-conception : Élimination automatique des tables orphelines et calculs redondants, réduisant l'empreinte carbone cloud de Spotify.

Synthèse stratégique & clés de succès

Un Modèle Moderne Fédéré : Unifier les données sans ralentir le cycle de déploiement agile des Squads.

La Gouvernance Invisible : Automatiser la conformité et la propriété par le code source (owner.yaml et Backstage).

Inclusion & Cyber-résilience : Intégrer les normes RGAA d'accessibilité et sécuriser l'infrastructure d'urgence face aux crises majeures (Plans Alpha et Beta).

****Remerciements**** : Je vous remercie pour votre attention et me tiens à votre entière disposition pour répondre à vos questions.